Android

Certificate Transparency

Transparency.dev Summit 2025

Roger Ng @ Google

Proprietary and Confidential

Roger Ng

Software Engineer, Google

Roger Ng is a software engineer at Google based in London, United Kingdom. He mainly works on Certificate Transparency and transparency logs in Google Open Source Security Team.

Proprietary and Confidential

Table of contents

01 Overview

02 How do Android Developers Opt-in to CT?

03 Technical Architecture

04 Challenges and Lessons Learned

05 Key Takeaway

Proprietary and Confidential

01

Overview

Android CT: API Level, Policy, Log List

Proprietary and Confidential

Overview

New

Support

Certificate transparency support is only available from:

- Android 16
- API level 36

Safe

Policy

The Android CT policy is aligned with other user agent CT policies.

- Same Signed Certificate Timestamps requirement
- Enforcement timeout:
  No log list is available on the device or the timestamp of the log list is older than 70 days ⟶ Disable CT enforcement

Caution

Log List

The log list is published in log_list.json on gstatic.com.

- Updated daily
- Support RFC 6962 and static-ct-api logs
- Audience: Android Connectivity module, Certificate Authorities, Monitors, Auditors
- Caution: The Android CT log list may not be used to facilitate CT enforcement in TLS clients other than the Android platform itself without explicit written permission from the Android CT team

Proprietary and Confidential

How to opt-in to CT

for Android Developers

Android

Proprietary and Confidential

Opt-in to CT is EASY

Network Security Configuration

Note: Certificate transparency support is only available from Android 16 (API level 36).

By default, the CT enforcement is disabled. An ‘opt-in by default’ update is on the roadmap.

```
<network-security-config>
  <base-config>
      <certificateTransparency enabled="true" />
  </base-config>
</network-security-config>
```

How about domain specific configuration?

For each `<domain-config>`, the evaluation follows this order:

1. If `certificateTransparency` is enabled, enable the verification.
2. If any `<trust-anchors>` is `"user"` or inline (i.e., `"@raw/cert.pem"`), disable the verification.
3. Otherwise, rely on the inherited configuration.

Opt-in to CT is FLEXIBLE

All domains have CT enabled except android.com and example.com.

Network Security Configuration

```
<network-security-config>
  <base-config>
    <certificateTransparency enabled="true" />
  </base-config>
  <domain-config>
    <domain includeSubdomains="false">android.com</domain>
    <certificateTransparency enabled="false" />
  </domain-config>
  <domain-config>
    <domain includeSubdomains="true">example.com</domain>
    <trust-anchors>
      <certificates src="user"/>
      <certificates src="@raw/debug_certificate"/>
    </trust-anchors>
  </domain-config>
</network-security-config>
```

Proprietary and Confidential

03

Technical Architecture

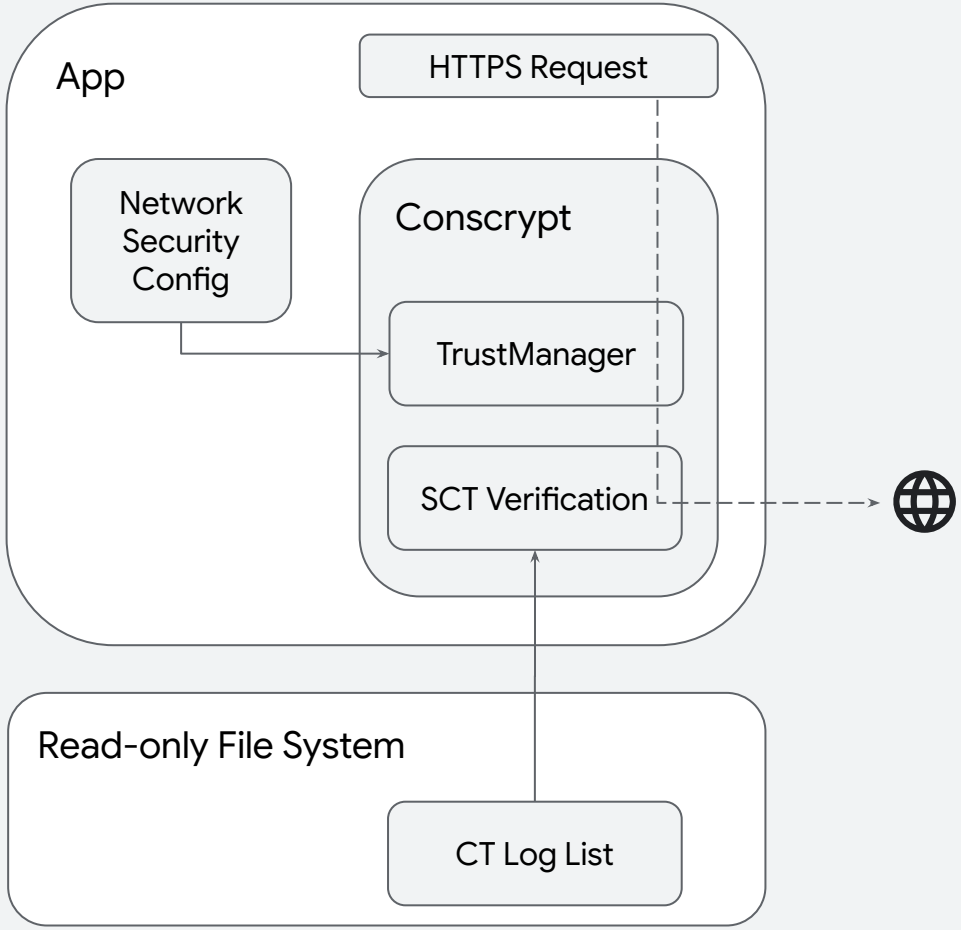
CT Enforcement (Conscrypt)

Android CT

Technical Architecture

CT Enforcement by Conscrypt

- When the app starts, Conscrypt's TrustManager reads CT configuration from Network Security Configuration of the app.
- Conscrypt reads the verified CT log list for SCT verification.
- When a HTTPS connection is created, apps are configured to use the platform's TrustManager, which uses Conscrypt's `TrustManagerImpl`, to validate the certificates from the connection.



Proprietary and Confidential

04

Challenges
Lessons Learned

How to bootstrap CT securely?
How to effectively distribute CT log list to billions of devices?

Proprietary and Confidential

Life of CT Log List on Device

Phase 1

Onboarding

No initial log list

Certificate Transparency Service in Connectivity Mainline module contains the log list URL.

Phase 2

Regular Update

Download every 24 hours

The log list is downloaded to a secure, read-only location within the operating system every 24 hours via Download Manager since device boot.

Log list verification and installation

Download log_list.sig file for signature verification against the public keys on devices. The public keys are distributed via software update. If the verification is a success, the log list will be installed to `/data/misc/keychain/ct/`.

The verified log list is now ready to be consumed by Conscrypt Mainline module for CT enforcement.

Unexpected Scenarios

Invalid log list signature

If the verification failed, the log list will not be installed. The existing on-device log list will remain in use.

Outdated log list

If the log list is outdated for 70 days for any reason, the CT enforcement is disabled.

Challenges

CT Policy Changes

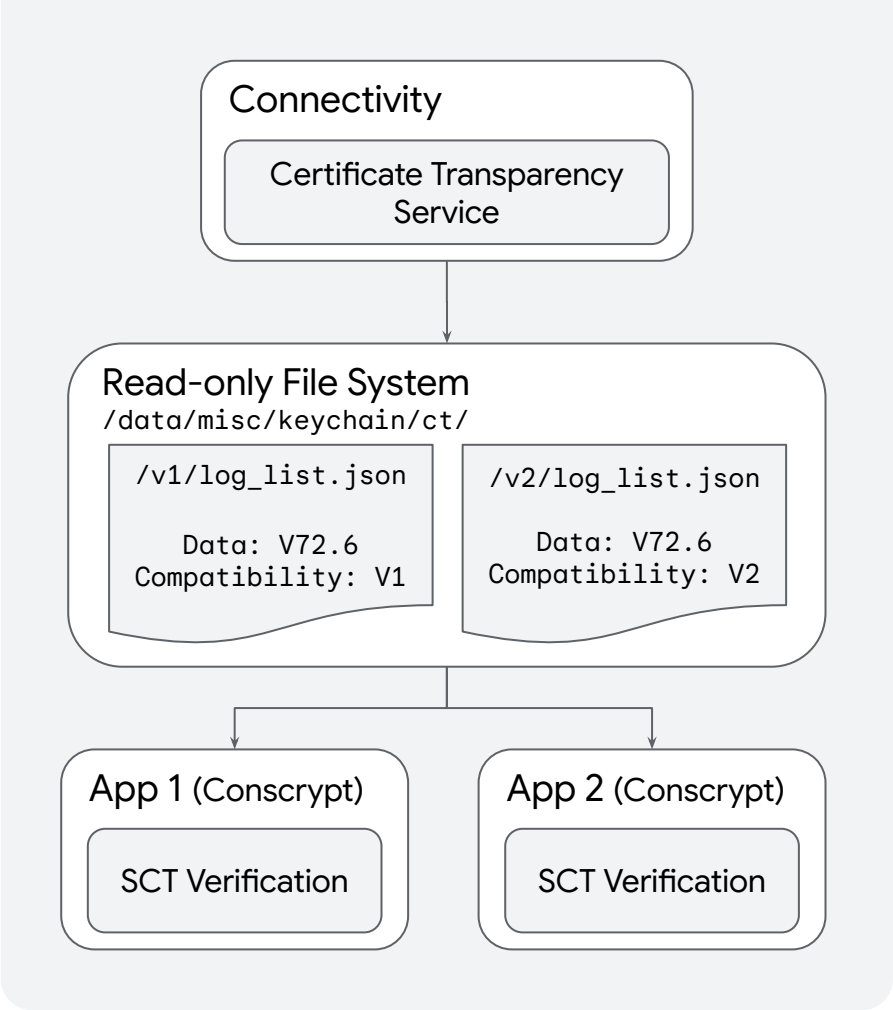
CT Log List Compatibility Version

When there is a CT policy change that requires a log list schema change or enforcement logic change, it is challenging to keep billions of devices up to date with these changes without breaking TLS connections.

- Connectivity Mainline module: Download, verify and install CT log list.
- Conscrypt Mainline module: Enforcement logic

Note that these two Mainline modules may not be in sync with the same CT policy.

CT log list compatibility version is the key to this challenge. The CT enforcement will fail-open when the Conscrypt enforcement compatibility version does not match with the installed log list. The support for older compatibility version is best effort only, there is no guarantee to keep older versions up to date.



Proprietary and Confidential

01

Key Takeaway

Call for Action

Proprietary and Confidential

“

Protect users from MITM attacks and misissued certs by opting in to Certificate Transparency in Android’s Network Security Config.

Proprietary and Confidential

Thank you

Proprietary and Confidential

FAQ

Will CT be backported to older Android versions?

Unfortunately, this isn't possible. There is no way to backport the CT configuration within the Network Security Configuration.

Is CT enforced in WebView within an app?

Yes, WebView enforces CT according to the policy specified in the app's Network Security Configuration.

What happen when CT enforcement is failed?

The app will get a SSL handshake exception with the message field containing information about the CT policy violation.

Is there a way to query the log list status on device?

There is currently no way for apps to query the status of the device's log list. We welcome feedback on whether such an API would be useful through our bug tracker.